

ECDAT (SIH26164) Research Report

Enterprise Cryptographic Discovery & Analysis Tool - NTRO - Software

Applies the 53-phase master prompt to a single, already-chosen problem statement. Selection and cross-PS phases are skipped. **Caveat:** the official SIH portal text was not reachable; details below come from public team repositories and must be verified against the portal. Scores are estimates, not measurements. Competitor claims come from search snippets, not full code reviews.

1. Verification (Phase 1)

Field	Status
PS ID	SIH26164 (consistent across many repos)
Title	Enterprise Cryptographic Discovery & Analysis Tool (ECDAT)
Organization	National Technical Research Organisation (NTRO)
Theme / Category	Blockchain & Cybersecurity, Software (one source only)
Requirements as echoed by teams	Discover every cryptographic asset in an enterprise codebase (source, binaries, libraries, container images), assess quantum risk, produce PQC migration plans. Artefacts: algorithms, keys, certificates, protocols, libraries, hardware, cloud services.
Ministry, exact constraints, expected outcome	Not available. Copy from the portal.

2. Historical winners (Phase 2)

A verified 10-year winner dataset could not be obtained in this search, so no year-wise table is given. Inference only: finalists tend to show a working end-to-end demo, real data, close fit to the ministry's ask, and strong Q&A.

3. Problem archaeology and workflow (Phases 3-4)

- **Real problem:** organizations do not know where their cryptography is. RSA, ECC and DH are scattered across code, dependencies, certificates, configs, containers, HSMs and cloud KMS.
- **Problem behind the problem:** data stolen today can be decrypted later by a quantum computer. Migration cannot be prioritized without an inventory, and an inventory cannot be trusted without knowing its completeness.
- **Unresolved bottleneck:** discovery coverage and trust. A scanner saying 'nothing found' cannot distinguish 'no crypto exists' from 'I could not see it'.

Workflow (text flowchart):

[Analyst login / RBAC]

- > [Select targets: repo, archive, image, endpoint]
- > [Ingest + validate + dedupe] (errors -> exception queue / admin review)
- > [Detectors: source, deps, certs, configs, binaries, TLS]
- > [Normalize to common asset + evidence model]
 - +> [Coverage and blind-spot engine] -> [Confidence per finding]
 - +> [Risk engine: quantum + classical + business context]
 - > [PQC / hybrid migration plan with cost and ordering]
- > [CBOM (CycloneDX) + SARIF + dashboard]
- > [Analyst feedback / suppress / re-scan diff] -> back to Normalize
- > [Audit log at every stage]

4. Existing solutions and competitor reality (Phases 5-7)

Commercial / open source (background knowledge, not verified in this search): IBM Quantum Safe Explorer and CBOMkit, SonarQube cryptography plugin, SandboxAQ AQtive Guard, Keyfactor AgileSec, CycloneDX CBOM standard, liboqs for the PQC side. Check pricing and capabilities before citing.

Other teams on this PS (confirmed from public repos): at least eight public repos already exist, several near-identical.

Repo / team	Notable features
NileshHalder/ECDAT	CycloneDX 1.6 CBOM, Mosca risk, 8 scanning channels, 3x3 risk matrix
givemehat/ECDAT	Quantum risk scanning, CBOM, Mosca integration (v1.0.0 release)
RohanExploit/q-darpan	On-prem, no GPU, CycloneDX 1.7, recommendations with wire-size cost
shriomverma100/FALCON (THETA172)	326 tests, 259 rules in 11 packs, SARIF, ML-DSA-signed evidence - high bar
KChethansai/ECDAT	Binaries, containers, dependencies, HSM refs, isolated opt-in runtime probe
tishanbrijesh-rgb/ECDAT-SIH	Separate confidence and coverage, conflict detection, blind spots
muzaffer26/ECDAT	Scanner-agnostic design, commit-to-commit diff to verify crypto retirement
Obaid211/ecdat	Blast-radius graph (NetworkX), TLS handshake sensor, SQLite inventory

Typical team builds: regex/AST scanner, CBOM JSON, Mosca calculation, quantum vulnerable/safe label, React dashboard, PQC mapping table.

100-team simulation (inference): 70 build scanner + CBOM + dashboard; 20 add Mosca, dependency graphs, SARIF; 8 add binaries, containers, diff engine, signed evidence; top 2 add confidence calibration, ground-truth benchmarks, CI integration.

Competition density: 9/10. The basic feature set is COMMON. 'Coverage vs confidence' is LESS COMMON but already taken by at least one repo. Measured accuracy against a labelled benchmark looks UNDEREXPLORED (I have not read each repo's code).

5. Research gap and technical bottleneck (Phases 8-10)

Existing approach	Limitation	Gap
Regex / AST rules	Misses wrappers, reflection, config-driven algorithm choice	LIKELY: precision/recall unmeasured
CBOM export	Inventory without completeness guarantees	UNDEREXPLORED: coverage quantification
Mosca's inequality	Needs shelf-life and migration-time inputs nobody has	LIKELY: context-aware priority
PQC mapping table	Ignores size, latency, protocol constraints	Partly covered by Q-DARPAN

The bottleneck is detection under incomplete visibility: crypto use is often indirect (libraries calling libraries, runtime config, stripped binaries). Deterministic rules and AST analysis are mature. LLM classification adds hallucination risk; at least one repo (Akkun77/ECDAT) deliberately avoids AI-generated classifications. Use an LLM, if at all, only to explain findings. Judges will ask 'why AI?' and the honest answer for detection is often 'you do not need it'.

6. Data audit (Phase 16)

- **Public inputs:** NIST FIPS 203/204/205, CycloneDX CBOM spec, open-source repos as scan targets.
- **Ground truth (hard part):** need labelled repos with known crypto usage. Build by seeding known crypto into open-source projects, or use academic benchmarks (verify names and licences).
- **Moat:** a seeded benchmark you create yourselves.

- **Privacy:** scanning enterprise code is sensitive. Run on-prem, never store private keys.

Scores: availability 8, quality 6, uniqueness 4, moat 5 (only with the benchmark), risk 3.

7. Feasibility and team fit (Phases 17-18)

- **Compute:** no GPU needed for the deterministic pipeline; a laptop with Docker is enough.
- **Stack:** FastAPI, PostgreSQL or SQLite, React, tree-sitter or Semgrep, Docker Compose. Avoid Kubernetes and microservices.
- **Team fit:** not scored - team skills unknown. Suggested split: scanners, risk/migration logic, benchmark/validation, UI/demo.

8. 72-hour go/no-go (Phase 19)

- **PASS:** scan 3 known repos with seeded crypto, export a valid CBOM, report precision/recall against seeded ground truth.
- **WARNING:** scanner works but no ground-truth measurement yet.
- **FAIL:** cannot parse two of the three target languages.
- **Pivot:** drop to Python and Java only; invest in the benchmark.

9. Failure modes (Phase 23, condensed)

#	Failure	Probability / impact	Mitigation
1	Demo looks identical to other teams	High / High	Benchmark + verified-migration demo
2	False positives on test or dead code	High / Medium	Test-path and reachability filtering
3	Missed detections reported as safe	Medium / High	Honest coverage statement
4	Overclaimed novelty	High / Medium	Separate engineering from research
5	Mosca inputs invented	Medium / Medium	Explicit user assumptions with justified defaults
6	Scope creep (binaries, runtime, cloud)	High / Medium	Cut to what you can validate
7	CBOM schema mismatch	Low / Medium	Validate against schema in CI
8	Demo environment failure	Medium / High	One-command Docker demo + recorded fallback

10. Hostile-judge questions (Phase 26, top 10)

1. What is novel versus IBM or Sonar tooling? Answer with your validated differentiator, not the feature list.
2. How accurate is detection? You need numbers from your benchmark.
3. Why is this AI? Say it is deliberately deterministic and explain why.
4. What about obfuscated or wrapped crypto calls? Show the blind-spot report.
5. Where do the Mosca inputs come from? User-supplied, with justified defaults.
6. Can NTRO deploy this air-gapped? Show the on-prem design.
7. What stops another team copying this? The benchmark and validation method.
8. What if the scan finds nothing? Show the coverage statement.
9. How does it scale to millions of lines? Show a measured scan time on a large repo.
10. What about data already exposed (harvest-now-decrypt-later)? Prioritize long-lived confidential data first.

11. Recommended differentiation

Flagship capability: a cryptographic inventory that tells you how much of the enterprise it could not see, and proves its detection accuracy against a seeded ground-truth benchmark.

- **Must build:** multi-language source and dependency detection, certificate and config scanning, CycloneDX CBOM, risk and migration plan, coverage and confidence reporting.
- **Differentiator:** seeded benchmark with published precision/recall and an ablation across detector types.
- **Should build:** commit-to-commit diff verifying a migration actually removed the weak algorithm (muzafer26 plans this; execute it better).
- **Do not build:** an LLM-based detector, or blockchain just because the theme says so.

Demo: 30 s - scan a repo, show the risk-ranked inventory. 60 s - show the blind-spot panel and one 'unseen' case. 5 min - run the benchmark live, apply a fix, re-scan, show the diff confirming retirement.

12. Scores (estimates)

Dimension	Score
Problem importance	9/10
Competition density	9/10 (high)
Innovation potential without validation angle	4/10
Innovation potential with benchmark	7/10
Feasibility	8/10
Copy resistance	4/10 base, 6/10 with benchmark
Judge defensibility	6/10 now, 8/10 with measured results
Research-paper potential	6/10

Bottom line: the problem is real and data is accessible, but several teams are building near-identical pipelines, and FALCON is a high bar. Winning depends on evidence (measured accuracy, honest coverage, verified-migration demo), not feature count.

Sources (public repositories consulted via search)

- github.com/tishanbrijesh-rgb/ECDAT-SIH
- github.com/Raja47-2/periperi-web
- github.com/Akkun77/ECDAT
- github.com/KChethansai/ECDAT
- github.com/NileshHalder/ECDAT
- github.com/muzafer26/ECDAT
- github.com/Obaid211/ecdat
- github.com/givemehat/ECDAT
- github.com/RohanExploit/q-darpan
- github.com/shriomverma100/FALCON